

บทที่ 4

การทดลองและผลการทดลอง

4.1 บทนำ

ในการทดลองจะเป็นการทดสอบระบบที่ได้สร้างขึ้นโดยแยกการทดสอบออกเป็น 4 การทดสอบ คือ

1. ทดสอบการเก็บข้อมูลทางด้านเครือข่าย
2. ทดสอบการเก็บข้อมูลจากเครื่องคอมพิวเตอร์
3. ทดสอบการแจ้งเตือนและวิเคราะห์
4. ทดสอบการกู้คืนระบบ
5. ทดสอบระบบโดยการจำลองสถานการณ์จริง

4.2 การทดสอบที่ 1 การเก็บข้อมูลทางด้านเครือข่าย

4.2.1 วิธีการทดสอบ

- 1) ทำการติดตั้งโปรแกรม Snort-Inline หลังจากนั้นปรับแต่งค่าคอนฟิกต่างๆ เพื่อให้โปรแกรมทำงานมีประสิทธิภาพมากขึ้นโดยการเพิ่มกฎ (rule) ต่างๆ ปรับแต่งให้โปรแกรมทำการส่งข้อมูลไปเก็บยังเครื่อง Log Server ปรับแต่งให้มีการแจ้งเตือนเมื่อพบแพ็กเก็ตที่น่าสงสัยว่าจะเป็นการละเมิดความปลอดภัยหรือการบุกรุก
- 2) เปิดระบบและเริ่มเก็บข้อมูลจากเครือข่าย และส่งข้อมูลทั้งหมดไปเก็บในฐานข้อมูลที่อยู่บนเครื่อง Log Server ผ่าน IPsec
- 3) ตรวจสอบการทำงานโดยใช้ส่วนแสดงผล สังเกตผลที่เกิดขึ้นและเปรียบเทียบระหว่างก่อนเริ่มเก็บข้อมูลและหลังจากทำการเก็บข้อมูลแล้ว

4.2.2 ผลการทดสอบ

จากการทดสอบพบว่า

- 1) ในฐานข้อมูลที่เครื่อง Log Server มีข้อมูลที่ได้จากโปรแกรม Snort-Inline
- 2) ปริมาณข้อมูลในฐานข้อมูลมีการเพิ่มขึ้นในขณะทำการเปิดระบบค้างไว้

ID	Signature	Priority	Timestamp	Ip_source	Ip_destination	Type
no data in database						

รูปที่ 4.1 แสดงการแสดงผลโดยที่ยังไม่มีการเริ่มเก็บข้อมูล

ID	Signature	Priority	Timestamp	Ip_source	Ip_destination	Type
41-(1-4911)	connect ftpd control		2006-02-19 21:09:04	161.246.5.27:33109	161.246.5.32:21	tcp
42-(1-4910)	connect ftpd control		2006-02-19 21:09:04	161.246.5.27:33109	161.246.5.32:21	tcp
43-(1-4909)	connect ftpd control		2006-02-19 21:09:04	161.246.5.27:33109	161.246.5.32:21	tcp
44-(1-4908)	connect ftpd control		2006-02-19 21:09:04	161.246.5.27:33109	161.246.5.32:21	tcp
45-(1-4907)	connect ftpd control		2006-02-19 21:08:59	161.246.5.27:33109	161.246.5.32:21	tcp
46-(1-4906)	connect ftpd control		2006-02-19 21:08:59	161.246.5.27:33109	161.246.5.32:21	tcp
47-(1-4905)	connect ftpd control		2006-02-19 21:08:53	161.246.5.27:33109	161.246.5.32:21	tcp
48-(1-4904)	connect ftpd control		2006-02-19 21:08:52	161.246.5.27:33109	161.246.5.32:21	tcp
49-(1-4903)	connect ftpd control		2006-02-19 21:08:52	161.246.5.27:33109	161.246.5.32:21	tcp
50-(1-4902)	connect ftpd control		2006-02-19 20:45:09	161.246.5.27:33006	161.246.5.32:21	tcp
51-(1-4901)	ICMP PING	3	2006-02-01 21:50:52	161.246.5.32:	12.16.24.128:	icmp
52-(1-4900)	ICMP PING *NIX	3	2006-02-01 21:50:52	161.246.5.32:	12.16.24.128:	icmp
53-(1-4899)	ICMP PING BSDtype	3	2006-02-01 21:50:52	161.246.5.32:	12.16.24.128:	icmp
54-(1-4898)	ICMP PING	3	2006-02-01 21:50:51	161.246.5.32:	12.16.24.128:	icmp
55-(1-4897)	ICMP PING *NIX	3	2006-02-01 21:50:51	161.246.5.32:	12.16.24.128:	icmp
56-(1-4896)	ICMP PING BSDtype	3	2006-02-01 21:50:51	161.246.5.32:	12.16.24.128:	icmp
57-(1-4895)	ICMP PING	3	2006-02-01 21:50:50	161.246.5.32:	12.16.24.128:	icmp
58-(1-4894)	ICMP PING *NIX	3	2006-02-01 21:50:50	161.246.5.32:	12.16.24.128:	icmp
59-(1-4893)	ICMP PING BSDtype	3	2006-02-01 21:50:50	161.246.5.32:	12.16.24.128:	icmp
60-(1-4892)	ICMP PING	3	2006-02-01 21:50:49	161.246.5.32:	12.16.24.128:	icmp

Event Payload		
Decode Payload (Binary)	String	Raw Packet
.....		PA SS tes t@ te st .c om ..

รูปที่ 4.2 แสดงข้อมูลที่ได้หลังจากทำการเก็บข้อมูลจากเครือข่าย

```

ESP(spi=0x000022b8,seq=0x4d83), length 88
06:30:24.549151 IP 172.16.24.128 > 172.16.24.130: AH(spi=0x0000457,seq=0x4603):
ESP(spi=0x00001e61,seq=0x4603), length 88
06:30:24.551636 IP 172.16.24.130 > 172.16.24.128: AH(spi=0x000008ae,seq=0x4d84):
ESP(spi=0x000022b8,seq=0x4d84), length 88
06:30:25.560984 IP 172.16.24.128 > 172.16.24.130: AH(spi=0x0000457,seq=0x4604):
ESP(spi=0x00001e61,seq=0x4604), length 88
06:30:25.561480 IP 172.16.24.130 > 172.16.24.128: AH(spi=0x000008ae,seq=0x4d85):
ESP(spi=0x000022b8,seq=0x4d85), length 88
06:30:26.548844 IP 172.16.24.128 > 172.16.24.130: AH(spi=0x0000457,seq=0x4606):
ESP(spi=0x00001e61,seq=0x4605), length 88
06:30:26.549261 IP 172.16.24.130 > 172.16.24.128: AH(spi=0x000008ae,seq=0x4d87):
ESP(spi=0x000022b8,seq=0x4d87), length 88
06:30:28.568329 IP 172.16.24.128 > 172.16.24.130: AH(spi=0x0000457,seq=0x4607):
ESP(spi=0x00001e61,seq=0x4607), length 88
06:30:28.568441 IP 172.16.24.130 > 172.16.24.128: AH(spi=0x000008ae,seq=0x4d88):
ESP(spi=0x000022b8,seq=0x4d88), length 88
06:30:29.587340 IP 172.16.24.128 > 172.16.24.130: AH(spi=0x0000457,seq=0x4608):
ESP(spi=0x00001e61,seq=0x4608), length 88
06:30:29.587916 IP 172.16.24.130 > 172.16.24.128: AH(spi=0x000008ae,seq=0x4d89):
ESP(spi=0x000022b8,seq=0x4d89), length 88
06:30:30.564213 IP 172.16.24.128 > 172.16.24.130: AH(spi=0x0000457,seq=0x4609):
ESP(spi=0x00001e61,seq=0x4609), length 88
06:30:30.565060 IP 172.16.24.130 > 172.16.24.128: AH(spi=0x000008ae,seq=0x4d8a):
ESP(spi=0x000022b8,seq=0x4d8a), length 88
06:30:31.505128 IP 172.16.24.128 > 172.16.24.130: AH(spi=0x0000457,seq=0x460a):
ESP(spi=0x00001e61,seq=0x460a), length 88
06:30:31.505648 IP 172.16.24.130 > 172.16.24.128: AH(spi=0x000008ae,seq=0x4d8b):
ESP(spi=0x000022b8,seq=0x4d8b), length 88

```

รูปที่ 4.3 แสดงการเข้ารหัสและตรวจสอบความถูกต้องของข้อมูลโดยผ่าน IPsec

4.3 การทดสอบที่ 2 การเก็บข้อมูลจากเครื่องคอมพิวเตอร์

4.3.1 วิธีการทดสอบ

- 1) ทำการติดตั้งโปรแกรม Syslog-ng และโปรแกรม Samhain หลังจากนั้นปรับแต่งค่าคอนฟิกต่างๆ เพื่อให้โปรแกรมทำงานมีประสิทธิภาพมากขึ้น ปรับแต่งให้โปรแกรมทำการส่งข้อมูลไปเก็บยังเครื่อง Log Server ปรับแต่งให้มีการตรวจสอบไฟล์ต่างๆ ตามที่กำหนด
- 2) เปิดระบบและเริ่มเก็บข้อมูลจากเครื่อง Response wall และส่งข้อมูลทั้งหมดไปเก็บในฐานข้อมูลที่อยู่บนเครื่อง Log Server ผ่าน IPsec
- 3) ตรวจสอบการทำงานโดยใช้ส่วนแสดงผล สังเกตผลที่เกิดขึ้นและเปรียบเทียบระหว่างก่อนเริ่มเก็บข้อมูลและหลังจากทำการเก็บข้อมูลแล้ว

4.3.2 ผลการทดสอบ

จากการทดสอบพบว่า

- 1) ในฐานข้อมูลที่เครื่อง Log Server มีข้อมูลที่ได้จากโปรแกรม Syslog-ng และโปรแกรม Samhain
- 2) ปริมาณข้อมูลในฐานข้อมูลมีการเพิ่มขึ้นในขณะที่ทำการเปิดระบบไว้

Index	File	Policies	TimeStamp	Owner	Sev
no data in database					

Index	Prog	Msg	TimeStamp	Priority	Msg	Facility
no data in database						

รูปที่ 4.4 แสดงการแสดงผลโดยที่ยังไม่มีการเริ่มเก็บข้อมูล

593		----	2006-01-31 20:29:13		MARK
592		----	2006-01-31 20:28:13		MARK
591	/etc/fstab	POLICY [ReadOnly] -----UGT-	2006-01-31 20:28:06	root	CRIT
590	/etc/mkinitrd/scripts	POLICY [ReadOnly] -----UGT-	2006-01-31 20:28:06	root	CRIT
589	/etc/mkinitrd/modules	POLICY [ReadOnly] -----UGT-	2006-01-31 20:28:05	root	CRIT
588	/etc/mkinitrd/mkinitrd.conf	POLICY [ReadOnly] -----UGT-	2006-01-31 20:28:05	root	CRIT
587	/etc/mkinitrd	POLICY [ReadOnly] -----UGT-	2006-01-31 20:28:05	root	CRIT
586	/etc/network/interfaces	POLICY [ReadOnly] -----UGT-	2006-01-31 20:28:05	root	CRIT
585	/etc/network/if-post-down.d	POLICY [ReadOnly] -----UGT-	2006-01-31 20:28:04	root	CRIT
584	/etc/network/if-pre-up.d	POLICY [ReadOnly] -----UGT-	2006-01-31 20:28:04	root	CRIT

1134	sudo	sudo: www-data : TTY=unknown ; PWD=/var/www/inprotect/main/recovery ; USER=root ; COMMAND=/var/www/inprotect/main/recovery/clear-restoring.sh	2006-01-31	notice	IPsec6	authpriv
1133	sudo	sudo: www-data : TTY=unknown ; PWD=/var/www/inprotect/main/recovery ; USER=root ; COMMAND=/var/www/inprotect/main/recovery/clear-restoring.sh	2006-01-31	notice	IPsec6	authpriv
1132	sudo	sudo: www-data : unable to look up IPsec6 via gethostbyname()	2006-01-31	alert	IPsec6	authpriv
1131	sudo	sudo: www-data : unable to look up IPsec6 via gethostbyname()	2006-01-31	alert	IPsec6	authpriv
1130	sudo	sudo: www-data : TTY=unknown ; PWD=/var/www/inprotect/main/recovery ; USER=root ; COMMAND=/usr/bin/rsync -vzpgt --stats --recursive --ignore-errors	2006-01-31	notice	IPsec6	authpriv

รูปที่ 4.5 แสดงข้อมูลที่ได้หลังจากทำการเก็บข้อมูลจากเครื่อง Response wall

4.4 การทดสอบที่ 3 การแจ้งเตือนและการวิเคราะห์

4.4.1 วิธีการทดสอบ

- 1) เปิดการทำงานทั้งหมดของระบบ
- 2) ทำการ scan ไปยังเครื่อง Response wall ด้วยโปรแกรม NMAP
- 3) Remote login ด้วย Secure Shell ไปยังเครื่อง Response wall และใส่รหัสผ่านที่ไม่ถูกต้อง ติดต่อกัน 3 ครั้ง
- 4) ทำการเปลี่ยนข้อมูลที่อยู่ในไฟล์สำคัญของระบบโดย และให้ขัดกับ Policy ของเครื่อง

4.4.2 ผลการทดสอบ

จากการทดสอบพบว่า ระบบมีการเก็บข้อมูลและแจ้งเตือนดังนี้คือ

- 1) มีการแจ้งเตือนว่า มีการ Scan โดยใช้โปรแกรม NMAP
- 2) มีการแจ้งเตือนว่า มีการพยายามใช้ Secure Shell ในการ Log in เข้าสู่ระบบ
- 3) มีการแจ้งเตือนว่า มีการเข้าไปแก้ไขหรือเปลี่ยนแปลงไฟล์สำคัญของระบบ

4.5 การทดสอบที่ 4 การกู้คืนระบบ

4.5.1 วิธีการทดสอบ

- 1) เปิดการทำงานทั้งหมดของระบบ
- 2) สร้างไฟล์ test โดยมีข้อมูล This is testing. ใน directory /etc/snort ที่เครื่อง Response wall
- 3) เพิ่ม path /etc/snort เข้าไปในระบบ Snapshot Management
- 4) ปรับแต่งค่าการเก็บ Snapshot ให้ทำงานดังนี้
 - Main Step ให้เก็บ Snapshot ในช่วงเวลา 2 เดือน โดยทำการเก็บทุกๆ 1 วัน
 - Sub Step ให้เก็บ Snapshot ในช่วงเวลา 20 นาที โดยทำการเก็บทุกๆ 1 นาที
- 5) ทำการเริ่มเก็บ Snapshot โดยคลิกที่ปุ่ม Start หลังจากให้ระบบได้ทำการเก็บ Snapshot เป็นเวลา 10 นาที เข้าไปตรวจสอบไฟล์ที่เกิดขึ้นใน directory /backup/snapshot/etc/snort/main และ /backup/snapshot/etc/snort/sub
- 6) เปลี่ยนข้อมูลที่อยู่ในไฟล์ test ใน directory /etc/snort ที่เครื่อง Response wall เป็น Content changed.
- 7) ตรวจสอบการเปลี่ยนแปลงจากข้อมูลที่ได้จากโปรแกรม Samhain และดำเนินการ Restore ไฟล์ test กลับไปยังเครื่อง Response wall
- 8) ตรวจสอบข้อมูลในไฟล์ test หลังจากการ Restore

4.5.2 ผลการทดสอบ

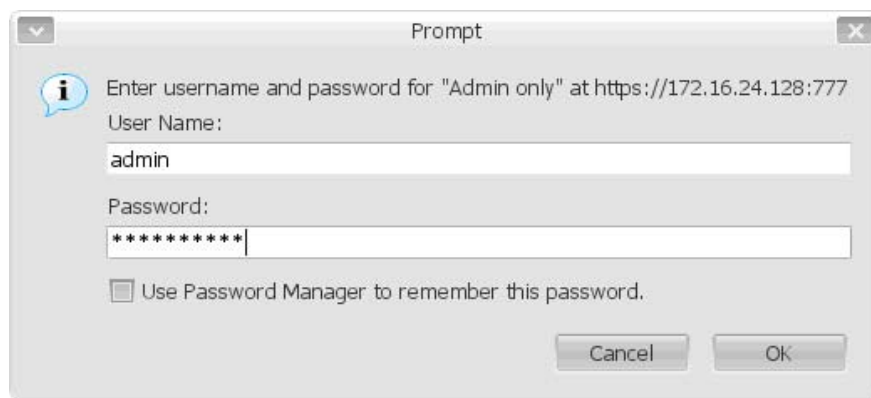
จากการทดสอบพบว่า

- 1) ระบบสามารถทำการเก็บ Snapshot ตาม path และช่วงเวลาที่กำหนดได้อย่างถูกต้อง
- 2) หลังจากทำการ restore ไฟล์ test กลับไปยังเครื่อง Response wall พบว่าข้อมูลในไฟล์กลับมาเป็น This is testing. เหมือนเดิม

4.6 การทดสอบที่ 5 การจำลองสถานการณ์จริง

4.6.1 จำลองขั้นตอนการตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัย

- 1) เปิดการทำงานทั้งหมดของระบบและเข้าสู่ระบบแสดงผลข้อมูลที่เครื่อง Log Server



รูปที่ 4.6 แสดงการพิสูจน์ตนเพื่อเข้าสู่ระบบ

Index	File	Policies	TimeStamp	Owner	Sev
no data in database					

Index	Prog	Msg	TimeStamp	Priority	Msg	Facility
no data in database						

ID	Signature	Priority	Timestamp	Ip_source	Ip_destination	Type
no data in database						

รูปที่ 4.7 แสดงข้อมูลในขณะที่ระบบยังไม่ถูกละเมิดความปลอดภัย

- 2) ทำการ Scan port ของเครื่อง Response wall
- 3) ทำการ Log in เข้าไปยังเครื่อง Response wall ผ่านทาง Secure Shell โดยใช้ Username เป็น Detector และรหัสผ่านใดๆ หลายๆ ครั้ง
- 4) ตรวจสอบเหตุการณ์ที่เกิดขึ้นกับ Response wall

25	sshd	::ffff:161.246.5.27 port 33427 ssh2	2006-02-21	info	IPsec4	auth
24	sshd	sshd[4871]: (pam_unix) 2 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=isag27.ce.lmitl.ac.th user=detector	2006-02-21	notice	IPsec4	auth
23	sshd	sshd[4871]: (pam_unix) 2 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=isag27.ce.lmitl.ac.th user=detector	2006-02-21	notice	IPsec4	auth
22	sshd	sshd[4871]: error: PAM: Have exhausted maximum number of retries for service. for detector from isag27.ce.lmitl.ac.th	2006-02-21	err	IPsec4	auth
21	sshd	sshd[4871]: error: PAM: Have exhausted maximum number of retries for service. for detector from isag27.ce.lmitl.ac.th	2006-02-21	err	IPsec4	auth
20	sshd	sshd[4871]: error: PAM: Authentication failure for detector from isag27.ce.lmitl.ac.th	2006-02-21	err	IPsec4	auth

รูปที่ 4.8 แสดงข้อมูลหลังจากที่ระบบถูกละเมิดความปลอดภัย

จากภาพพบเหตุการณ์ผิดปกติ คือ โดน scan port โดยมาจาก IP 161.246.5.27 และ มีการพยายามเข้ามายังเครื่องเป้าหมายโดยการเข้ามาทาง ssh และมาจากเครื่อง 161.246.5.27 โดยที่เข้า

มาโดยใช้ชื่อผู้ชื่อว่า detector โดยมีการ ป้อนรหัสผ่านผิดเกินจำนวนที่กำหนด แต่สุดท้ายก็สามารถเข้าสู่ระบบได้

5) ทำการสืบหาร่องรอยที่น่าสงสัยจากข้อมูลที่ได้มา

Index	File	Policies	TimeStamp	Owner	Sev
16	/etc/passwd	POLICY [ReadOnly] C-----TS	2006-02-21 12:21:45		CRIT
15		---- TIMESTAMP ----	2006-02-21 12:21:11		MARK
14		---- TIMESTAMP ----	2006-02-21 12:20:11		MARK
13		---- TIMESTAMP ----	2006-02-21 12:19:11		MARK
12		---- TIMESTAMP ----	2006-02-21 12:18:11		MARK
11		---- TIMESTAMP ----	2006-02-21 12:17:11		MARK
10		---- TIMESTAMP ----	2006-02-21 12:16:11		MARK
9		---- TIMESTAMP ----	2006-02-21 12:15:11		MARK
8		---- TIMESTAMP ----	2006-02-21 12:14:11		MARK

รูปที่ 4.9 แสดงข้อมูลที่บ่งบอกถึงการเปลี่ยนแปลงที่ไฟล์ /etc/passwd

จากข้อมูลที่ได้ทำให้ทราบว่า มีการแจ้งเตือนในระดับวิกฤต เนื่องจากการเปลี่ยนแปลงไฟล์ /etc/passwd ซึ่งเป็นไฟล์ที่เก็บชื่อผู้ใช้และ คำต่างๆ ของผู้ใช้ระบบ

ทำการตรวจสอบต่อไปเพื่อหาข้อมูลช่วงเวลาที่ไฟล์ /etc/passwd โดนเปลี่ยนแปลง หลังจากได้ช่วงเวลาที่แน่นอนแล้ว ขั้นตอนต่อไปคือการตรวจสอบการใช้งานระบบในช่วงนั้นเพื่อดูว่า มีผู้ใช้ระบบคนใดบ้างที่เข้าใช้งานระบบช่วงเวลานั้นๆ

CheckLogin AddToRestore CheckDiff			
File	/etc/passwd		
Msg	POLICY [ReadOnly] C-----TS		
CTime-old	2006-02-21 05:00:29	CTime-new	2006-02-21 12:13:03
MTime-old	2006-02-21 05:00:29	MTime-new	2006-02-21 12:13:03
Owner-old		Owner-new	
Attr-old		Attr-new	
Mode-old		Mode-new	
Size-old	1000	Size-new	997

รูปที่ 4.10 แสดงข้อมูลที่บ่งบอกถึงช่วงเวลาที่ไฟล์ /etc/passwd โดนเปลี่ยนแปลง

User	Serial	IP	Login time	Logout time
detector	pts/0	161.246.5.27	2006-02-21 12:09	2006-02-21 12:20
root	tty1	0.0.0.0	2006-01-31 20:21	Still log in

รูปที่ 4.11 แสดงข้อมูลที่บ่งบอกถึงการใช้งานระบบ

จากข้อมูลที่ได้ทำให้ทราบว่า ผู้ที่ใช้งานระบบมีเพียงคนเดียวในช่วงเวลาที่ไฟล์ /etc/passwd โดนเปลี่ยนแปลง คือผู้ใช้ชื่อ detector ที่ทำการเข้าสู่ระบบตั้งแต่เวลา 19.31 น. ถึงเวลา 19.48 น.

- 6) ทำการตรวจสอบต่อไปว่าผู้ใช้นั้นมีการใช้คำสั่งอะไรบ้างในระหว่างช่วงเวลาที่มีการ login เข้าสู่ระบบซึ่งปรากฏว่ามีการใช้คำสั่งที่น่าสงสัย คือ คำสั่ง su จึงเข้าไปตรวจสอบต่อยัง Logfile ของระบบ

Command	Flag	User	Terminal	Time	Date
sshd	SF	detector	??	0.53	21 12:08 Feb
bash	F	detector	??	0.00	21 12:09 Feb
bash	F	detector	??	0.00	21 12:09 Feb
sshd	SF	detector	??	0.05	21 12:01 Feb
bash	F	detector	??	0.00	21 12:01 Feb
bash	F	detector	??	0.00	21 12:01 Feb
bash		detector	??	0.07	21 12:08 Feb
ls		detector	??	0.01	21 12:19 Feb
clear		detector	??	0.00	21 12:10 Feb
clear		detector	??	0.00	21 12:10 Feb
dircolors		detector	??	0.00	21 12:09 Feb
id		detector	??	0.00	21 12:09 Feb
bash		detector	??	0.07	21 12:01 Feb
clear		detector	??	0.01	21 12:07 Feb
dircolors		detector	??	0.00	21 12:01 Feb
id		detector	??	0.00	21 12:01 Feb

รูปที่ 4.12 แสดงข้อมูลที่บ่งบอกการใช้คำสั่งของผู้ใช้งานระบบ

Index	Prog	Msg	TimeStamp	Priority	Msg	Facility
52	sudo	sudo: detector : TTY=pts/0 ; PWD=/home/detector ; USER=root ; COMMAND=/bin/bash	2006-02-21	notice	IPsec4	authpriv
51	sudo	sudo: detector : TTY=pts/0 ; PWD=/home/detector ; USER=root ; COMMAND=/bin/bash	2006-02-21	notice	IPsec4	authpriv
50	syslog-ng	syslog-ng[2657]: STATS: dropped 0	2006-02-21	notice	IPsec4	syslog
49	syslog-ng	syslog-ng[2657]: STATS: dropped 0	2006-02-21	notice	IPsec4	syslog
48	sudo	sudo: detector : unable to lookup IPsec4 via gethostbyname()	2006-02-21	alert	IPsec4	authpriv
47	sudo	sudo: detector : unable to lookup IPsec4 via gethostbyname()	2006-02-21	alert	IPsec4	authpriv
46	CRON	CRON[4208]: (root) mail session closed for user root	2006-02-21	info	IPsec4	authpriv

รูปที่ 4.13 แสดงข้อมูลที่บ่งบอการรายละเอียดของการใช้คำสั่งของผู้ใช้งานระบบ

จากข้อมูลที่ได้ทำให้ทราบว่าผู้ใช้ชื่อ detector มีการใช้คำสั่ง sudo และไม่มีข้อผิดพลาด
แจ้งเตือน

CheckLogin AddToRestore CheckDiff

File	/etc/passwd		
Msg	POLICY [ReadOnly] C-----TS		
CTime-old	2006-02-21 05:00:29	CTime-new	2006-02-21 12:13:03
MTime-old	2006-02-21 05:00:29	MTime-new	2006-02-21 12:13:03
Owner-old		Owner-new	
Attr-old		Attr-new	
Mode-old		Mode-new	
Size-old	1000	Size-new	997



You can check file different From : /backup/snapshot/etc/main/200601311943 and:/backup/snapshot/etc/200602211234

รูปที่ 4.14 แสดงผลของระบบจากการหาข้อแตกต่างของไฟล์ที่พบการเปลี่ยนแปลง

- 7) ทำการตรวจสอบจากข้อมูลของไฟล์ว่าถ้าต้องการดูการเปลี่ยนแปลงของไฟล์ /etc/passwd ที่เครื่องเก็บล็อกสามารถเข้าไปดูได้ที่ไหน จึงได้ path 2 path ที่จะนำมาใช้ในการตรวจสอบความแตกต่าง

```
IPsec6:/backup/snapshot/etc/sub# diff 200602211319/etc/passwd ../main/200601311943/etc/passwd
23,24c23
< detector:x:0:1001:,,,:/home/detector:/bin/bash
< ftp:x:103:65534:./home/ftp:/bin/false
---
> detector:x:1001:1001:,,,:/home/detector:/bin/bash
IPsec6:/backup/snapshot/etc/sub# █
```

รูปที่ 4.15 แสดงการหาข้อแตกต่างของไฟล์ที่โดนเปลี่ยนแปลง

เข้าไปตรวจสอบดูความแตกต่างของไฟล์ทั้ง 2 ที่ ปรากฏว่ามีการเปลี่ยนแปลงจากไฟล์ก่อนหน้าคือ ผู้ใช้ detector มีการเปลี่ยน user id จากเดิมที่เป็น 1001 มาเป็น 0 ซึ่งทำให้ผู้ใช้นั้นมีสิทธิ์เทียบเท่ากับ root

Port Scan

Target :

172.16.24.130

Go

☐ -sP Ping Scan.

☐ -sT TCP connect() port scan.

☐ -sU UDP port scan.

☐ -PO Don't ping hosts.

```

Starting nmap 3.81 ( http://www.insecure.org/nmap/ ) at 2006-01-25 18:29 ICT
Interesting ports on 172.16.24.130:
(The 1661 ports scanned but not shown below are in state: closed)
PORT      STATE SERVICE
22/tcp    open  ssh
873/tcp   open  rsync

Nmap finished: 1 IP address (1 host up) scanned in 1.551 seconds

```

Process 2.46 seconds

รูปที่ 4.16 แสดงการตรวจสอบการเปิดพอร์ต

ทำการตรวจสอบระบบว่ามีการเปิด port หรือ backdoor ไว้หรือไม่โดยการใช้เครื่อง logserver สแกน เครื่องที่โดนบุกรุก ปรากฏว่าไม่มีการเปิด port หรือบริการใดๆเพิ่มขึ้นจากปกติ จากนั้นก็ทำการตรวจสอบว่าเวลาปัจจุบันมีใครใช้ระบบอยู่บ้าง แต่ ปรากฏว่าไม่มี จึงเข้าไปตรวจสอบ ที่เครื่องจริงว่าไฟล์นั้นมีการเปลี่ยนแปลงไปจริงหรือไม่

จากข้อมูลที่ได้มาทั้งหมด ทำให้ทราบได้ค่อนข้างแน่นอนว่า ผู้บุกรุกได้เข้ามาโดยใช้ชื่อผู้ชื่อว่า detector โดยที่เข้ามาทางบริการ ssh และมีการใช้ช่องโหว่จากการกำหนดขอบเขตของคำสั่ง sudo ที่ไม่ดีพอเพื่อได้สิทธิ์ของ root ไปและยังได้ทำการเปลี่ยนแปลงสิทธิ์ของตนเองเพื่อให้ได้มาซึ่งสิทธิ์ที่สูงขึ้น คือเป็น root และมีการลบค่าล็อกต่างๆ เนื่องจากมีการแจ้งเตือนว่า ไฟล์ /var/log มีขนาดเล็กลง เมื่อเข้าไปตรวจสอบค่าล็อกที่เครื่องซึ่งโดนโจมตี ปรากฏว่ามีการลบค่าต่างๆ ทิ้งไป

8) ทำการกู้คืนระบบ

Recovery

File	Time
/etc/passwd	200602211213

File

Select time Time year Month Day Hour Min Sec

รูปที่ 4.17 แสดงการเพิ่มไฟล์เข้าไปในระบบการ Recovery

ทำการกู้คืนระบบโดยการแก้ค่าไฟล์ที่โดนเปลี่ยนแปลงให้กับเป็นค่าเหมือนกับตอนก่อนถูกเปลี่ยนแปลง

```
GNU nano 1.2.4      File: /etc/passwd

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody::0:65534:nobody:/nonexistent:/bin/sh
Debian-exim:x:102:102::/var/spool/exim4:/bin/false
tum:x:1000:1000:Taweesak Meksikarin,,,:/home/tum:/bin/bash
identd:x:100:65534::/var/run/identd:/bin/false
sshd:x:101:65534::/var/run/sshd:/bin/false
detector:x:1001:1001:,,,:/home/detector:/bin/bash

[ Read 23 lines ]
^G Get Help  ^O WriteOut  ^R Read File ^Y Prev Page ^K Cut Text  ^C Cur Pos
^X Exit      ^J Justify   ^W Where Is  ^N Next Page ^U UnCut Txt ^T To Spell
```

รูปที่ 4.18 แสดงการเข้าไปตรวจสอบค่าหลังจากที่ได้ทำการกู้คืนระบบ

Adding New Path

Path

List Of Path

No.	Path name	Status	Action
1	/etc	Working	▶ □ ✕

Snapshot Configure : /etc

Keep snapshot (Main Step)

Round Reuse

Years
 Months
 Days

Keep snapshot every

Years
 Months
 Days

Keep snapshot (Sub Step)

Round Reuse

Days
 Hours

Keep snapshot every

Hours
 Minutes

รูปที่ 4.19 แสดงการตั้งค่าช่วงเวลาของการเก็บ Snapshot

เข้าไปเพิ่มการเก็บ Snapshot ให้ทำการเก็บเพิ่มที่ ไดรฟ์ทอรั ของผู้ใช้ detector และทำการเพิ่มความถี่ในการเก็บ Snapshot ให้ถี่ขึ้น

4.6.2 จำลองการละเมิดความปลอดภัย

- 1) ชื่อผู้ใช้นี้หนึ่งของเครื่องที่ต้องการโจมตี ชื่อ detector ผู้บุกรุกจึงได้ทำการ scan เครื่องเป้าหมายเพื่อตรวจสอบว่ามีบริการใดเปิดไว้อย่าง เพื่อที่จะเข้าไปโจมตีระบบ หลังจากทีทราบบริการที่เปิด ผู้บุกรุกก็ได้ทำการ เลือก บริการที่จะเข้า และทดสอบเดารหัสผ่าน ซึ่งอยู่ใกล้ตัวของผู้ใช้นั้นๆ ปรากฏว่าสามารถเข้าสู่ระบบได้

```

Isag27:/home/phantomb# nmap 161.246.5.32

Starting Nmap 3.95 ( http://www.insecure.org/nmap/ ) at 2006-02-21 12:07 ICT
Interesting ports on isag32.ce.kmitl.ac.th (161.246.5.32):
(The 1665 ports scanned but not shown below are in state: closed)
PORT      STATE      SERVICE
21/tcp    open      ftp
22/tcp    open      ssh
113/tcp   open      auth
179/tcp   filtered  bgp
873/tcp   open      rsync
MAC Address: 00:0C:29:F8:44:27 (VMware)

Nmap finished: 1 IP address (1 host up) scanned in 9.375 seconds
Isag27:/home/phantomb# ssh detector@161.246.5.32
Password:
Password:
Permission denied (publickey,keyboard-interactive).
Isag27:/home/phantomb# ssh detector@161.246.5.32
Password:
Linux IPsec4 2.6.11.7 #1 Tue Jan 17 08:22:54 ICT 2006 i686 GNU/Linux

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.

Last login: Tue Feb 21 12:01:10 2006 from isag27.ce.kmitl.ac.th
detector@IPsec4:~$ █

```

รูปที่ 4.20 แสดงการ Log in เข้าใช้บริการยังเครื่องเป้าหมาย

ผู้บุกรุกได้ทำการทดสอบคำสั่ง และ สิ่งที่มีอยู่ ปรากฏว่าผู้บุกรุกได้เจอ คำสั่ง sudo จึงได้ทดสอบโดยลองเรียกเชลล์ของ root ดูปรากฏว่า สามารถได้เชลล์ของ root เนื่องจากการตั้งค่าสำหรับ คำสั่ง sudo ไว้ไม่ดี ผู้บุกรุกจึงได้เป็น root

```

detector@IPsec4:~$ su
su          sudo          sudoedit      sum          superformat  suspend
detector@IPsec4:~$ sudo -s -H
sudo: unable to lookup IPsec4 via gethostbyname()
Password:
IPsec4:/home/detector# id
uid=0(root) gid=0(root) groups=0(root)
IPsec4:/home/detector# █

```

รูปที่ 4.21 แสดงการทดสอบการใช้คำสั่ง sudo

ผู้บุกรุกเข้าไปที่ ไฟล์ /etc/passwd และได้ทำการเปลี่ยน user id ของตัวเองให้เป็น 0 เพื่อให้มีสิทธิ์เท่ากับ root

```

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody::0:65534:nobody:/nonexistent:/bin/sh
Debian-exim:x:102:102::/var/spool/exim4:/bin/false
tum:x:1000:1000:Taweesak Meksikarin,,,:/home/tum:/bin/bash
identd:x:100:65534::/var/run/identd:/bin/false
sshd:x:101:65534::/var/run/sshd:/bin/false
detector:x:0:1001:,,,:/home/detector:/bin/bash
ftp:x:103:65534::/home/ftp:/bin/false

```

รูปที่ 4.22 แสดงการเข้าไปแก้ไขข้อมูลในไฟล์ /etc/passwd

ผู้บุกรุกเข้าไปดูที่ /var/log ซึ่งเก็บ ล็อกไฟล์ต่างๆ ของระบบ เพื่อที่จะได้ทำการแก้ไข

```

Feb 21 12:00:59 IPsec4 sshd[4850]: (pam_unix) 2 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=isa$
Feb 21 12:01:10 IPsec4 sshd[4855]: Accepted keyboard-interactive/pam for detector from ::ffff:161.246.5.27 port 33312 ssh2
Feb 21 12:01:10 IPsec4 sshd[4858]: (pam_unix) session opened for user detector by (uid=0)
Feb 21 12:05:01 IPsec4 CRON[4864]: (pam_unix) session opened for user root by (uid=0)
Feb 21 12:05:01 IPsec4 CRON[4864]: (pam_unix) session closed for user root
Feb 21 12:07:19 IPsec4 sshd[4858]: (pam_unix) session closed for user detector
Feb 21 12:09:07 IPsec4 sshd[4871]: (pam_unix) authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=isag27.ce.k$
Feb 21 12:09:08 IPsec4 sshd[4871]: error: PAM: Authentication failure for detector from isag27.ce.kmitl.ac.th
Feb 21 12:09:12 IPsec4 sshd[4871]: error: PAM: Authentication failure for detector from isag27.ce.kmitl.ac.th
Feb 21 12:09:15 IPsec4 sshd[4871]: error: PAM: Have exhausted maximum number of retries for service. for detector from isag27$
Feb 21 12:09:15 IPsec4 sshd[4871]: (pam_unix) 2 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=isa$
Feb 21 12:09:22 IPsec4 sshd[4876]: Accepted keyboard-interactive/pam for detector from ::ffff:161.246.5.27 port 33427 ssh2
Feb 21 12:09:22 IPsec4 sshd[4879]: (pam_unix) session opened for user detector by (uid=0)
Feb 21 12:10:01 IPsec4 CRON[4885]: (pam_unix) session opened for user root by (uid=0)
Feb 21 12:09:48 IPsec4 CRON[4885]: (pam_unix) session closed for user root
Feb 21 12:10:01 IPsec4 CRON[4891]: (pam_unix) session opened for user root by (uid=0)
Feb 21 12:10:00 IPsec4 CRON[4891]: (pam_unix) session closed for user root
Feb 21 12:11:05 IPsec4 sudo: detector : unable to lookup IPsec4 via gethostbyname()
Feb 21 12:11:11 IPsec4 sudo: detector : TTY=pts/0 ; PWD=/home/detector ; USER=root ; COMMAND=/bin/bash

```

รูปที่ 4.23 แสดงการเข้าไปดูข้อมูลในไฟล์ /var/log

ผู้บุกรุกทำการลบข้อมูลบรรทัดที่จะเป็นหลักฐานความผิดของตัวเอง และเหลือไว้เพียงเหตุการณ์ที่ดูเป็นปกติ

```
Feb 21 12:01:10 IPsec4 sshd[4858]: (pam_unix) session opened for user detector by (uid=0)
Feb 21 12:05:01 IPsec4 CRON[4864]: (pam_unix) session opened for user root by (uid=0)
Feb 21 12:05:01 IPsec4 CRON[4864]: (pam_unix) session closed for user root
Feb 21 12:07:19 IPsec4 sshd[4858]: (pam_unix) session closed for user detector
Feb 21 12:09:22 IPsec4 sshd[4876]: Accepted keyboard-interactive/pam for detector from ::ffff:161.246.5.27 port 33427 ssh2
Feb 21 12:09:22 IPsec4 sshd[4879]: (pam_unix) session opened for user detector by (uid=0)
Feb 21 12:10:01 IPsec4 CRON[4885]: (pam_unix) session opened for user root by (uid=0)
Feb 21 12:09:48 IPsec4 CRON[4885]: (pam_unix) session closed for user root
Feb 21 12:10:01 IPsec4 CRON[4891]: (pam_unix) session opened for user root by (uid=0)
Feb 21 12:10:00 IPsec4 CRON[4891]: (pam_unix) session closed for user root
Feb 21 12:15:01 IPsec4 CRON[4909]: (pam_unix) session opened for user root by (uid=0)
Feb 21 12:14:42 IPsec4 CRON[4909]: (pam_unix) session closed for user root
Feb 21 12:15:01 IPsec4 CRON[4915]: (pam_unix) session opened for user root by (uid=0)
Feb 21 12:15:00 IPsec4 CRON[4915]: (pam_unix) session closed for user root
Feb 21 12:17:01 IPsec4 CRON[4922]: (pam_unix) session opened for user root by (uid=0)
Feb 21 12:17:01 IPsec4 CRON[4922]: (pam_unix) session closed for user root
```

รูปที่ 4.24 แสดงข้อมูลในไฟล์ /var/log หลังจากที่ได้แก้ไขแล้ว